WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Sensitive Data Exposure — Database Dump Accessible in Web Root

Finding NVP-016 · **High**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-016
Vulnerability	Sensitive Data Exposure — Database Dump Accessible in Web Root
Severity	**High**
CVSS 4.0	7.5 `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`
CWE	CWE-540 (Information Exposure Through Source); CWE-200
OWASP	A05:2021 Security Misconfiguration
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

The application ships its MySQL dump (newsportal.sql) inside the web root, downloadable without authentication. It discloses the full schema and seeded administrator credential hashes.

2. Affected Target

Affected URL	http://localhost/newsportal/newsportal/newsportal.sql
Affected parameter	n/a
Affected role	Unauthenticated
Authentication	None

3. Technical Description

A direct GET to /newsportal.sql returns the 18 KB SQL dump (HTTP 200) containing CREATE TABLE/INSERT statements, including the tbladmin seed row with the administrator username and MD5 password hash. Combined with weak MD5 (NVP-010), this yields credentials; it also reveals the complete data model to aid further attacks.

4. Root Cause Analysis

```
Deployment artifact newsportal.sql left in the publicly served directory
/opt/lampp/htdocs/newsportal/newsportal/ with no access restriction.
```

5. Preconditions

Knowledge/guess of the dump path (the product name is the conventional filename). No account required.

6. Proof of Concept — Step-by-Step Reproduction

1. Request GET /newsportal/newsportal/newsportal.sql.
2. Server returns HTTP 200, ~18,648 bytes containing the full schema and seed data (13+ SQL statements).
3. The tbladmin INSERT exposes the administrator username + MD5 password hash and email addresses.

7. HTTP Request Evidence

```
GET /newsportal/newsportal/newsportal.sql HTTP/1.1
Host: localhost
```

8. HTTP Response Evidence

```
HTTP/1.1 200 OK
Content-Length: 18648
...
INSERT INTO `tbladmin` (`id`,`AdminUserName`,`AdminPassword`,`AdminEmailId`,`userType`,...) VALUES
(1,'admin','<md5>',...);
```

9. Proof of Concept — Visual Evidence

> **Evidence note:** Verified live (HTTP 200, 18,648 bytes, 13 SQL statements). Dump content not redistributed; only metadata recorded.

10. Actual Security Impact

Unauthenticated disclosure of the database schema and seeded admin credential hash (crackable via NVP-010), plus email addresses that feed the password-reset takeover (NVP-004). A direct path to administrator compromise.

Exploitation complexity	Low — single unauthenticated GET at a predictable path.
Realistic attack scenario	Attacker downloads the dump, cracks the MD5 admin hash or uses the email with NVP-004, and logs in as administrator.

11. Remediation Recommendations

Remove all .sql dumps/backups from the web root; block direct access to such files at the web server; never ship production dumps; rotate any exposed credentials.

Secure code example

```
# Apache: <FilesMatch "\.(sql|bak|old|zip)$">  Require all denied  </FilesMatch>
# and relocate dumps outside the document root.
```

12. Retesting Procedure

Request the dump path; a fixed system returns 403/404 and the file is not present in the web root.

13. References

- CWE-540
- CWE-200
- OWASP WSTG-CONF-04
- OWASP A05:2021

14. Conclusion

Confirmed unauthenticated exposure of the DB dump (schema + admin hash). Verified live.